

Software and Mobile Security

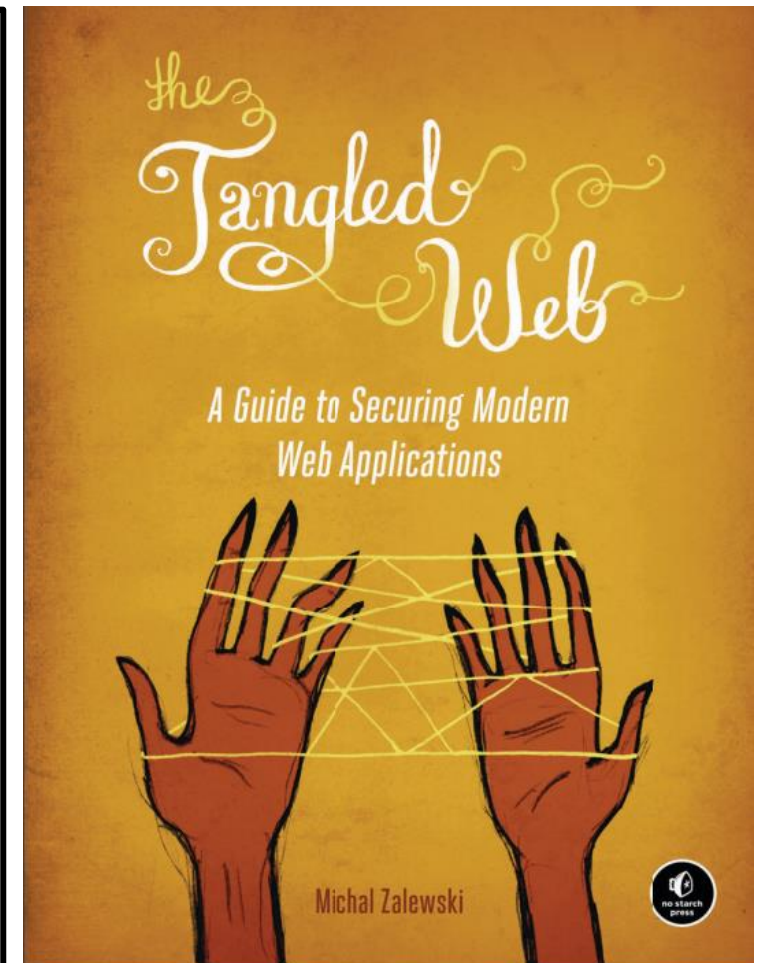
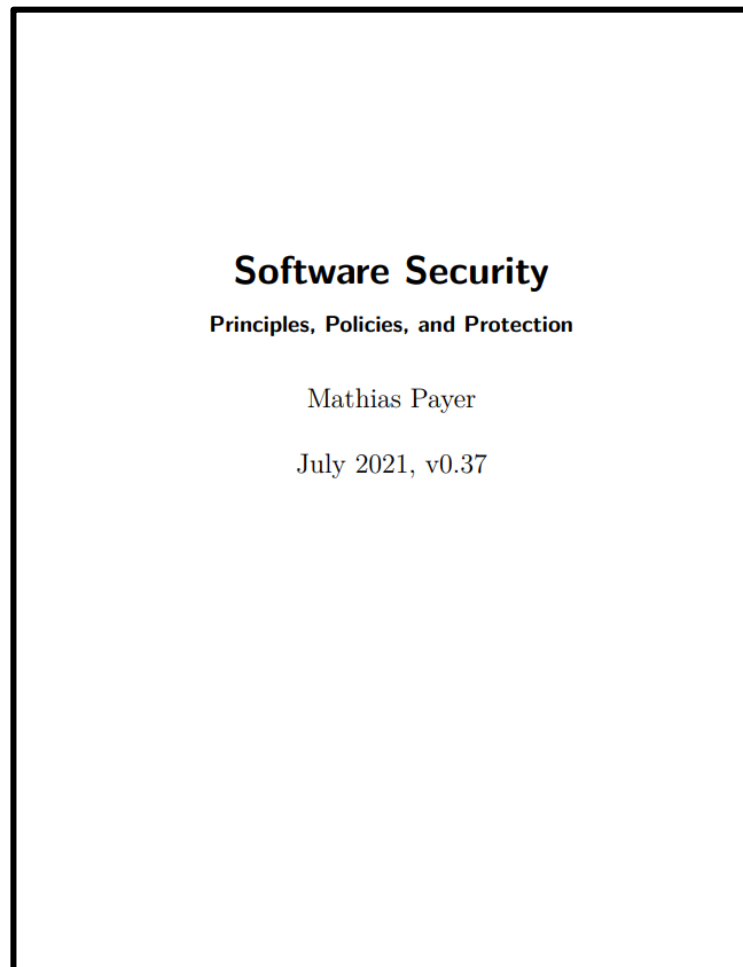
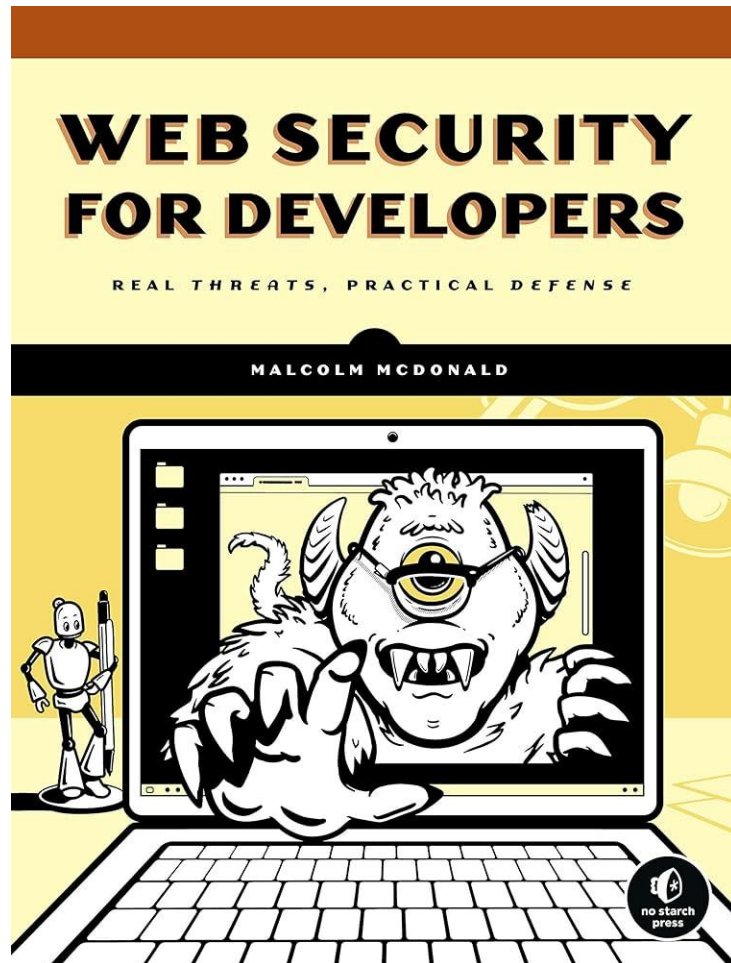
Dr. Hanan Hindy

hanan.hindy@cis.asu.edu.eg





Helpful Resources



* Lecture content is based on [CS 253 Web Security](#)

Proposed Course Outline

- Part 1: Basics
- Part 2: Client-Side Attacks and Defenses
- Part 3: Server-Side Attacks and Defenses
- Part 4: Mobile Security
- Privacy

Grading Scheme

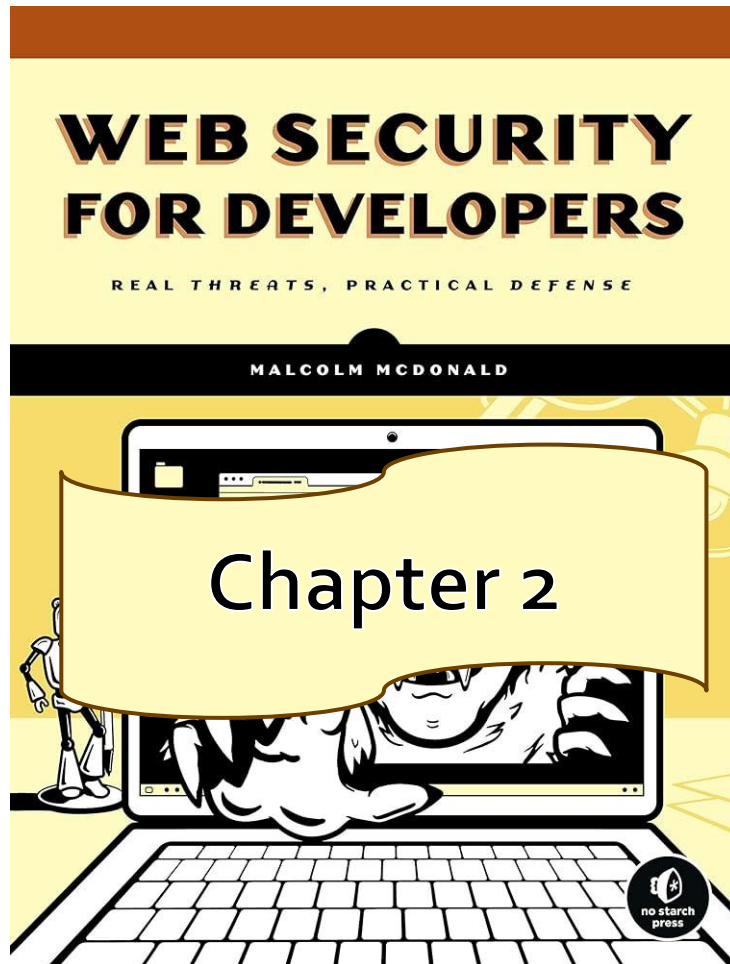
• Midterm	20%
• Quizzes	20%
• Practical	20%
• Final Exam	40%

Office Hours

- Thursday: 12 pm – 2 pm
- Office: A111
- Email: hanan.hindy@cis.asu.edu.eg



This Lecture



Software Security

Principles, Policies, and Protection

Mathias Payer

July 2021, v0.37

Chapter 2

What is Software Security?

- Software security refers to a **set of practices** that help **protect** software applications and digital solutions from attackers.
- Developers incorporate these practices/techniques into the software development life cycle and testing processes.
- As a result, companies can ensure their digital solutions remain secure and are able to function in the event of a malicious attack.

What is Software Security?

- The goal of software security is to allow any intended use of software but prevent any unintended use.



Software Security

- Software Security is the area of security that focuses on (i) testing, (ii) evaluating, (iii) improving, (iv) enforcing, and (v) proving security properties of software.

Course Main Goal

- Building a Security Mindset (attacker and defender).



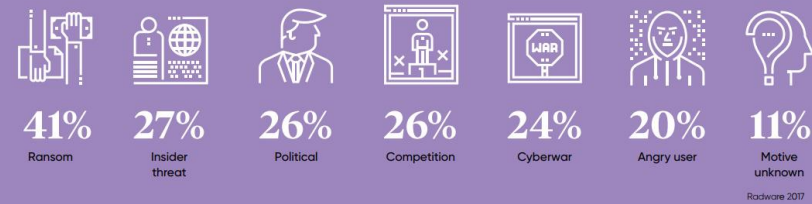
Why Software Security?

- Most software systems today contain numerous flaws and bugs that get exploited by attackers.
- Social engineering is very effective and has high success rates.
- New threats emerge everyday.
- Convenience trumps security measures.
- Exponential increase in vulnerabilities in software systems.
- And much more....

WHY HACKERS HACK

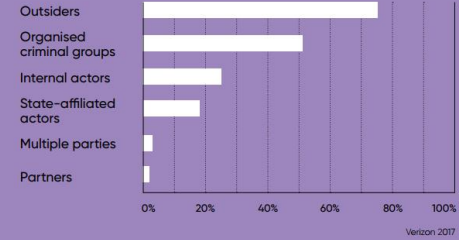
MOTIVES BEHIND CYBERATTACKS

GLOBAL STUDY OF LARGE ORGANISATIONS THAT WERE VICTIMS TO A CYBERATTACK



WHO'S BEHIND DATA BREACHES?

GLOBAL STUDY OF ALMOST 2,000 DATA BREACHES



DATA BREACHES, BY PATTERN AND MOTIVE

GLOBAL STUDY OF ALMOST 2,000 DATA BREACHES



RACONTEUR

MOTIVES BEHIND CYBERATTACKS

GLOBAL STUDY OF LARGE ORGANISATIONS THAT WERE VICTIMS TO A CYBERATTACK



41%

Ransom



27%

Insider
threat



26%

Political



26%

Competition



24%

Cyberwar



20%

Angry user

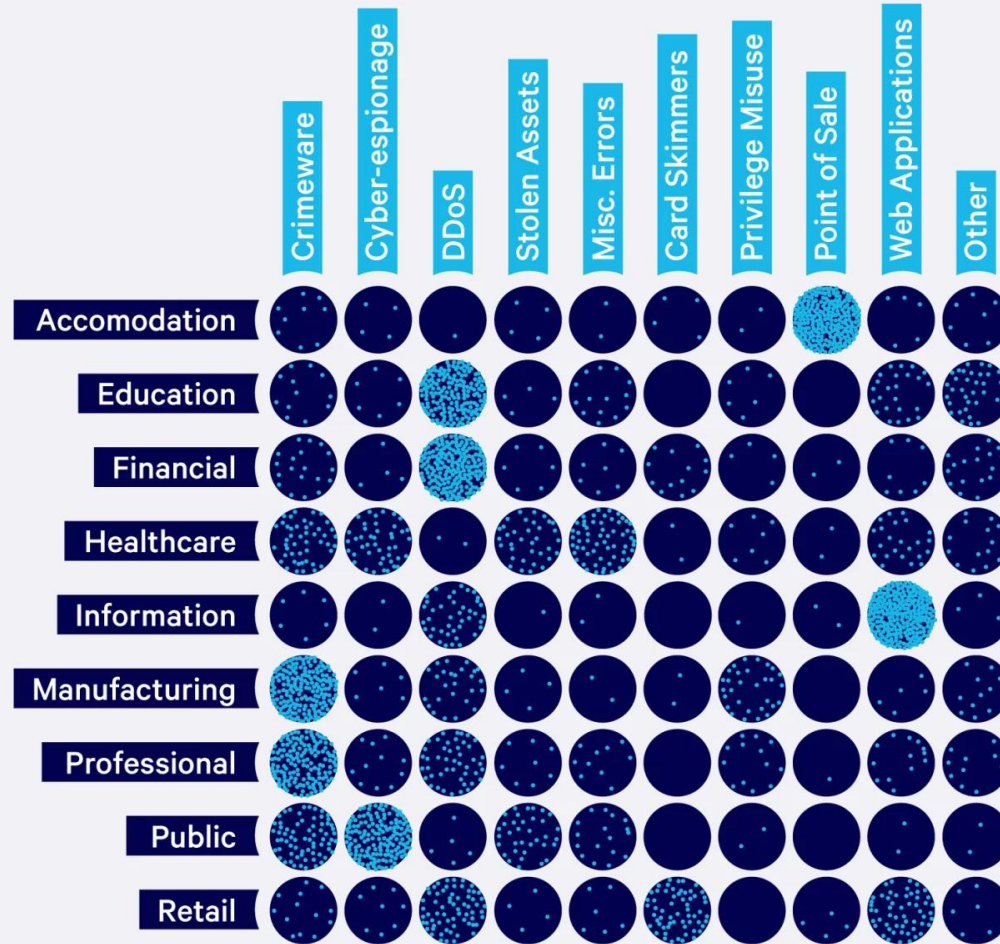


11%

Motive
unknown

Radware 2017

Cyber Incidents By Industry



(Data covering 2017)

Aspects of Secure Coding / Software Security Principles



Software Security Principles

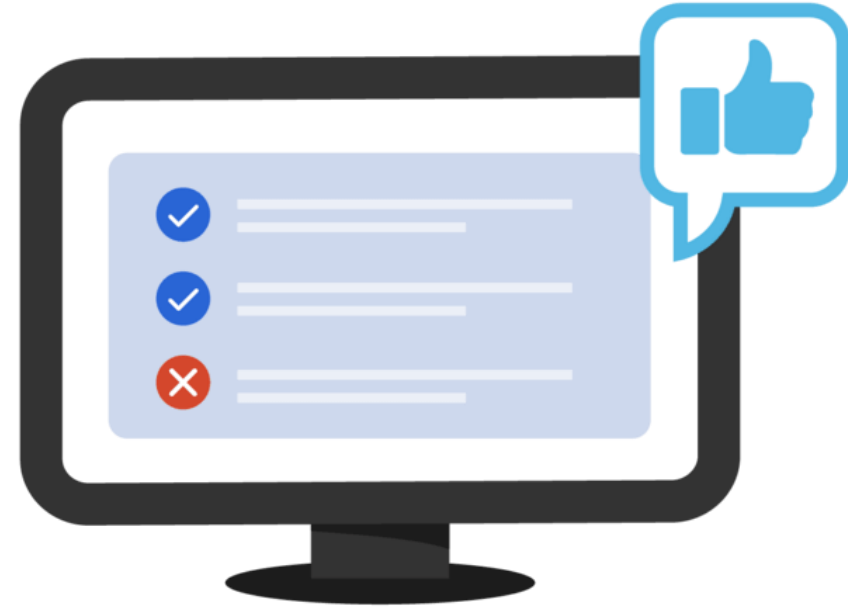
- Authentication is the process of verifying if someone is who they claim to be.
- Access Rights/Authorization encode what entities a user has access to.

Authentication



Confirms users
are who they say they are.

Authorization



Gives users permission
to access a resource.

Isolation & Least privilege

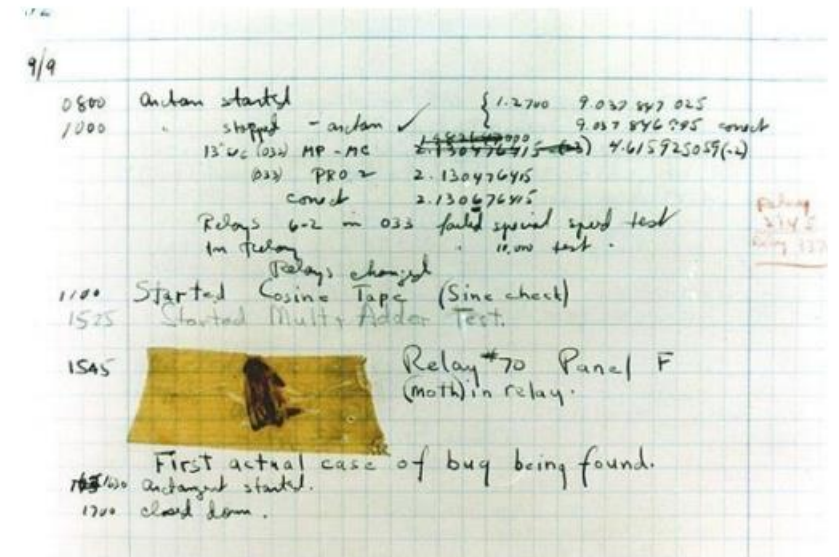
- Isolation enforces the separation between components such that interaction is only possible along a well-defined interface that allows reasoning about access primitives.
- Least privilege ensures that each software component executes with the minimum amount of privileges.

Threat Modeling

- Threat modeling is the process of **enumerating** and **prioritizing** all potential threats to a system
- Threat modeling evaluates questions such as:
 - What are the high value-assets in a system?
 - Which components of a system are most vulnerable?
 - What are the most relevant threats?

Bug Vs. Vulnerability

- A “bug” is a flaw in a computer program or system that results in an unexpected outcome.
- The term “bug” comes from a moth that deterred computation of a Harvard Mark II computer in 1947. Grace Hopper noted the system crash in the operation log as “first actual case of bug being found”



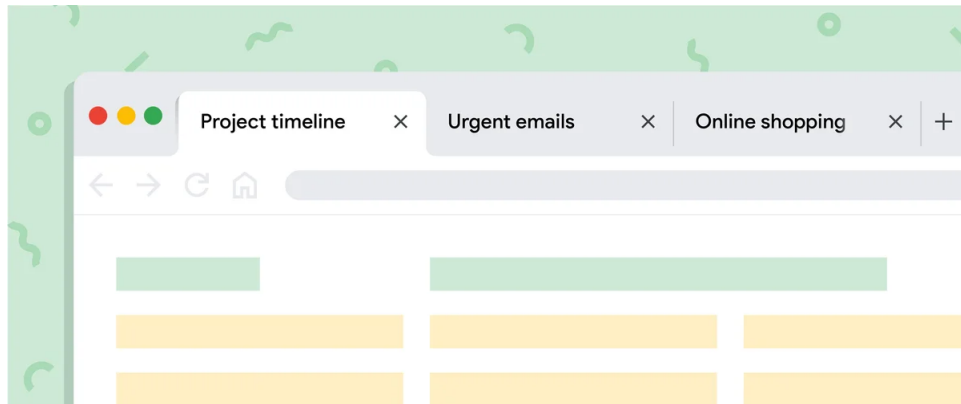
Bug Vs. Vulnerability

- A vulnerability is a software weakness that allows an attacker to exploit a software bug.
- A vulnerability requires three key components
 - (i) system is susceptible to flaw,
 - (ii) adversary has access to the flaw (e.g., through information flow), and
 - (iii) adversary has capability to exploit the flaw.



What is Web Security?

1. Browser Security



StackExchange sign up log in tour help stack overflow careers search

stackoverflow Questions Tags Users Badges Unanswered Ask Question

Stack Overflow is a question and answer site for professional and enthusiast programmers. It's 100% free. Take the 2-minute tour

Using `fi` in mysql query is not working using this approach

Cloud Storage: Conquer Business Data SOFTLAYER Control your storage via integrated object storage API. LEARN MORE

asked today
viewed 5 times

Looking for a job?

Digital Team Leader
SCL Group
London, UK
lamp agile

Software Developer Consultant -
Singapore
ThoughtWorks
Singapore
ruby-on-rails c#

Mid/Senior Fullstack Ruby
Engineer
ReferralCandy
Singapore
ruby-on-rails aws-opsworks

Senior Software Engineer (Scala /
Functional Language Developer)
Citadel Technology Solutio...
Singapore / relocation

if its not `fi` I'm getting the right result but when I'm using it **UNDEFINED VARIABLE**.

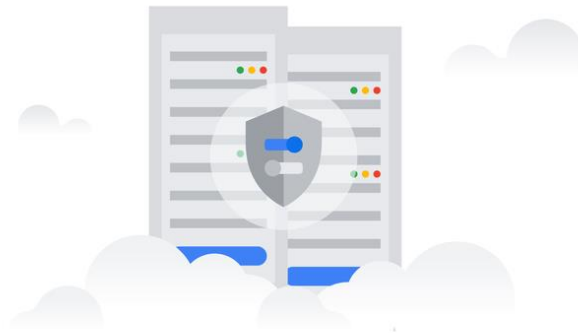
here's my approach to search the \$location and all Collation and operation in database is SET to "utf8_general_ci"

```
<?php
/**$location = $_GET['location'];*/
$location = $_GET['location'];
echo $location; //to check if I'm getting the right data
$result = $db->prepare("SELECT * FROM list WHERE loc = '". mysql_real_escape_stri
$result->execute();
for($i=0; $row = $result->fetch(); $i++){
    $title=$row['title'];
    $fname=$row['fname'];
    $lname=$row['lname'];
    $lname=$row['lname'];
    $addri=$row['addr'];
    $posti=$row['position'];
    $location=$row['loc'];
}
?>
```

mysql utf-8 where

What is Web Security?

2. Server-Side Security



What is Web Security?

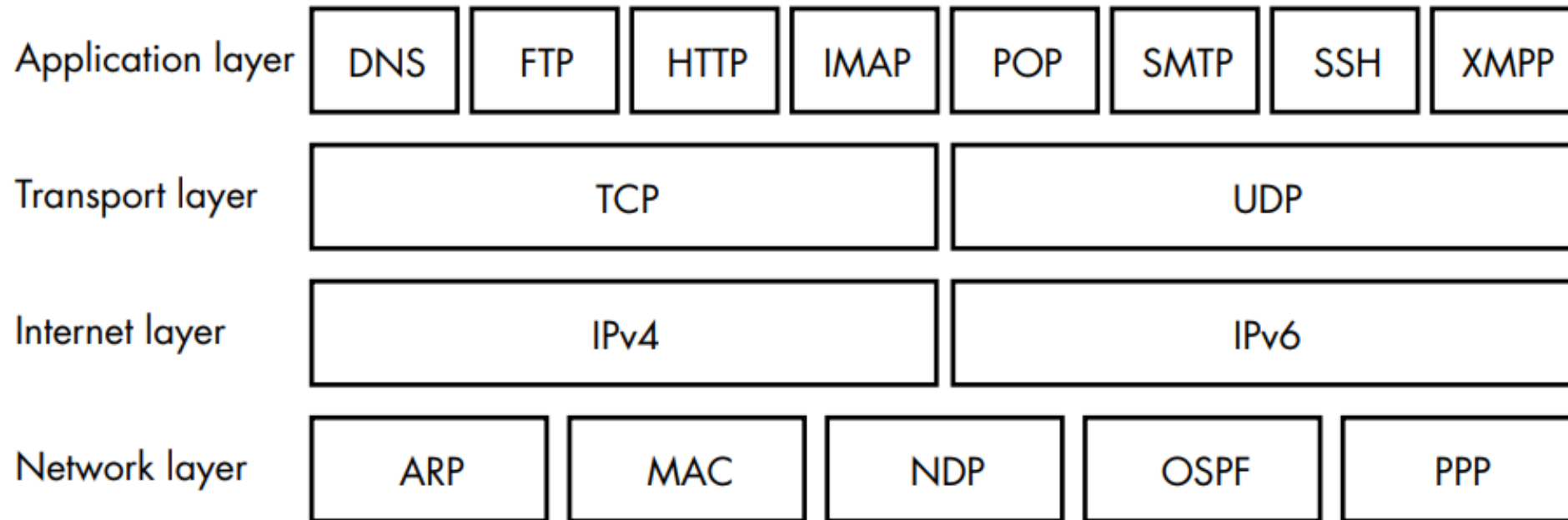
3. Client-Side Security

Why is web security hard?

- Different sites interacting in the same tab ("mashups")
- Low-level features; hardware access
- Desire for high performance
- APIs were not designed from first principles; evolved
- Strict backwards compatibility requirements

Modern web applications are built on a tangle of technologies that have been developed over time and then haphazardly pieced together. Every piece of the web application stack, from HTTP requests to browser-side scripts, comes with important yet subtle security consequences. To keep users safe, it is essential for developers to confidently navigate this landscape.

IP Protocol Stack



IP Addresses & DNS

IP Address

192.168.1.1

DNS

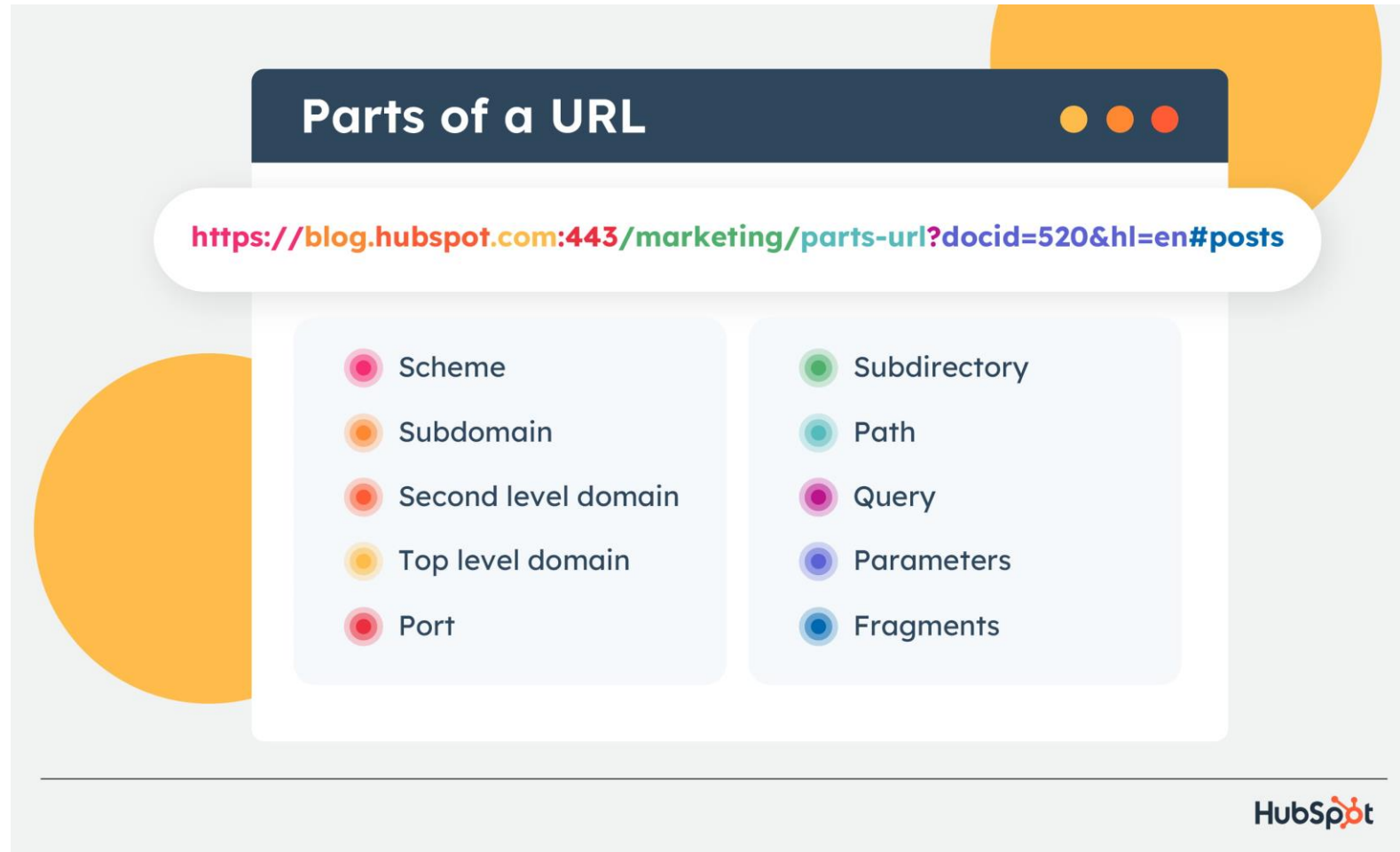
- The Domain Name System (DNS) is the phonebook of the Internet.
- Humans access information online through **domain names**, while Web browsers interact through **IP**.
- DNS translates domain names to IP addresses.

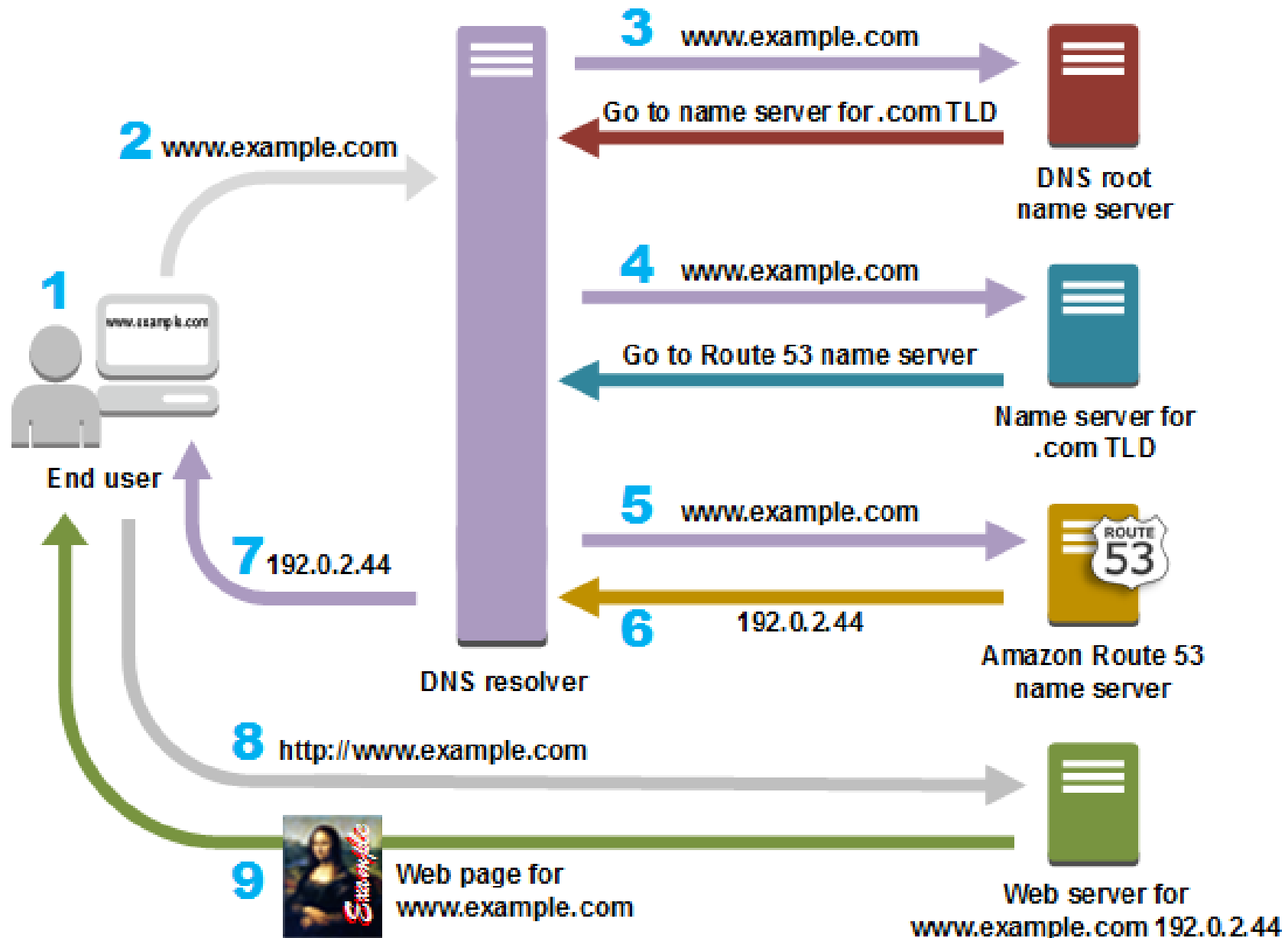
URL Structure

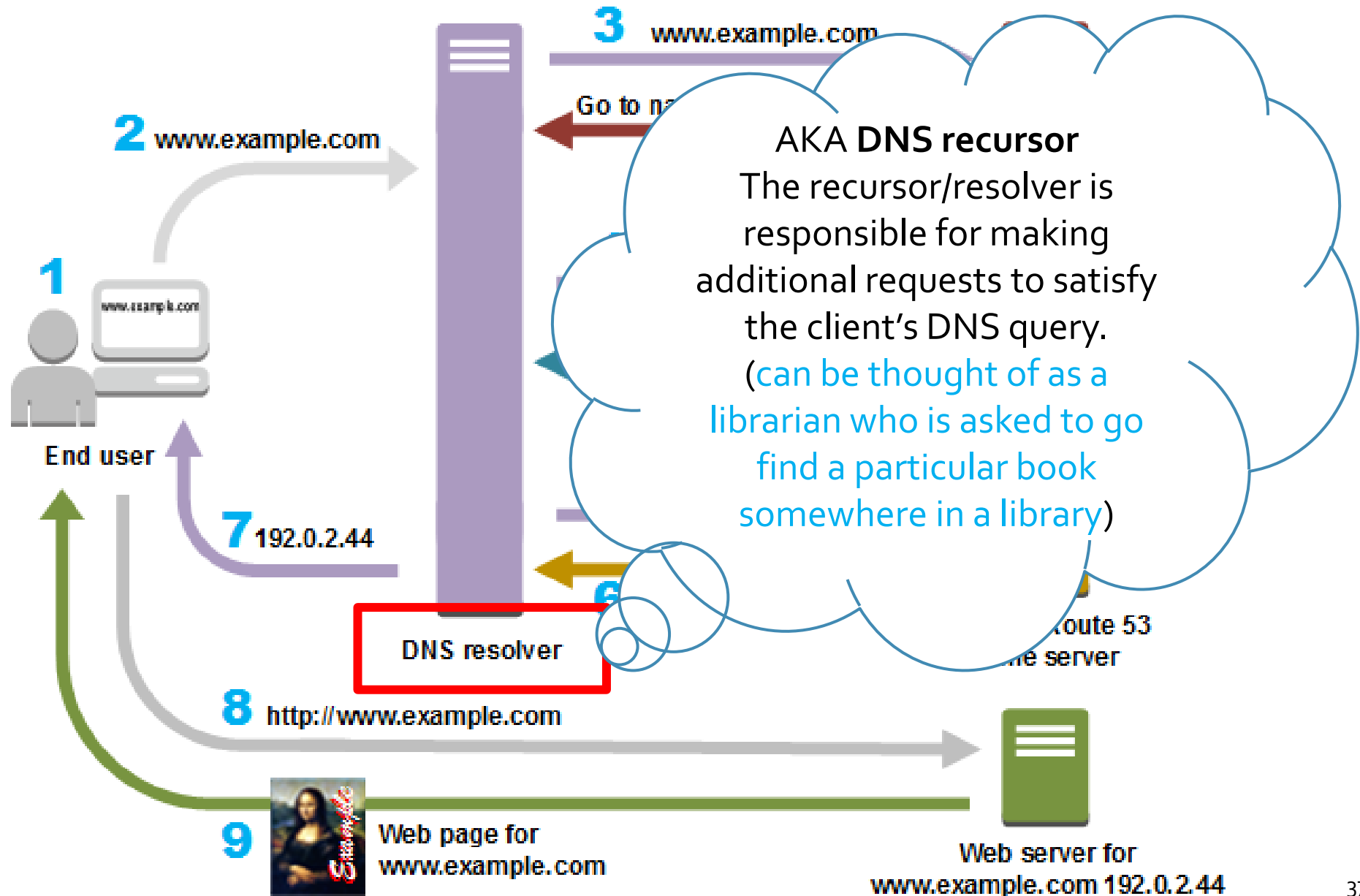
<https://blog.hubspot.com:443/marketing/parts-url?docid=520&hl=en#posts>

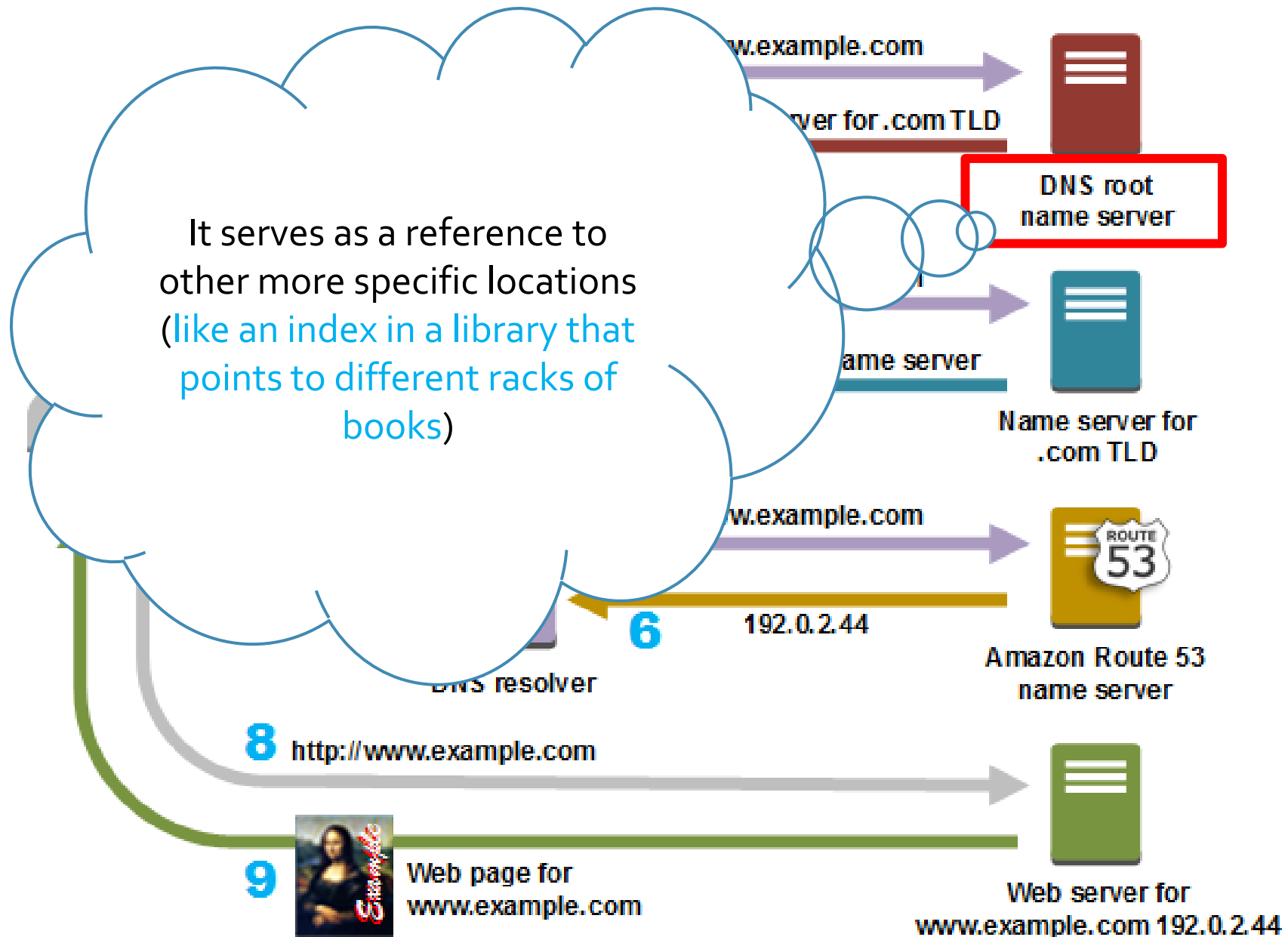
<https://blog.hubspot.com/marketing/parts-url>

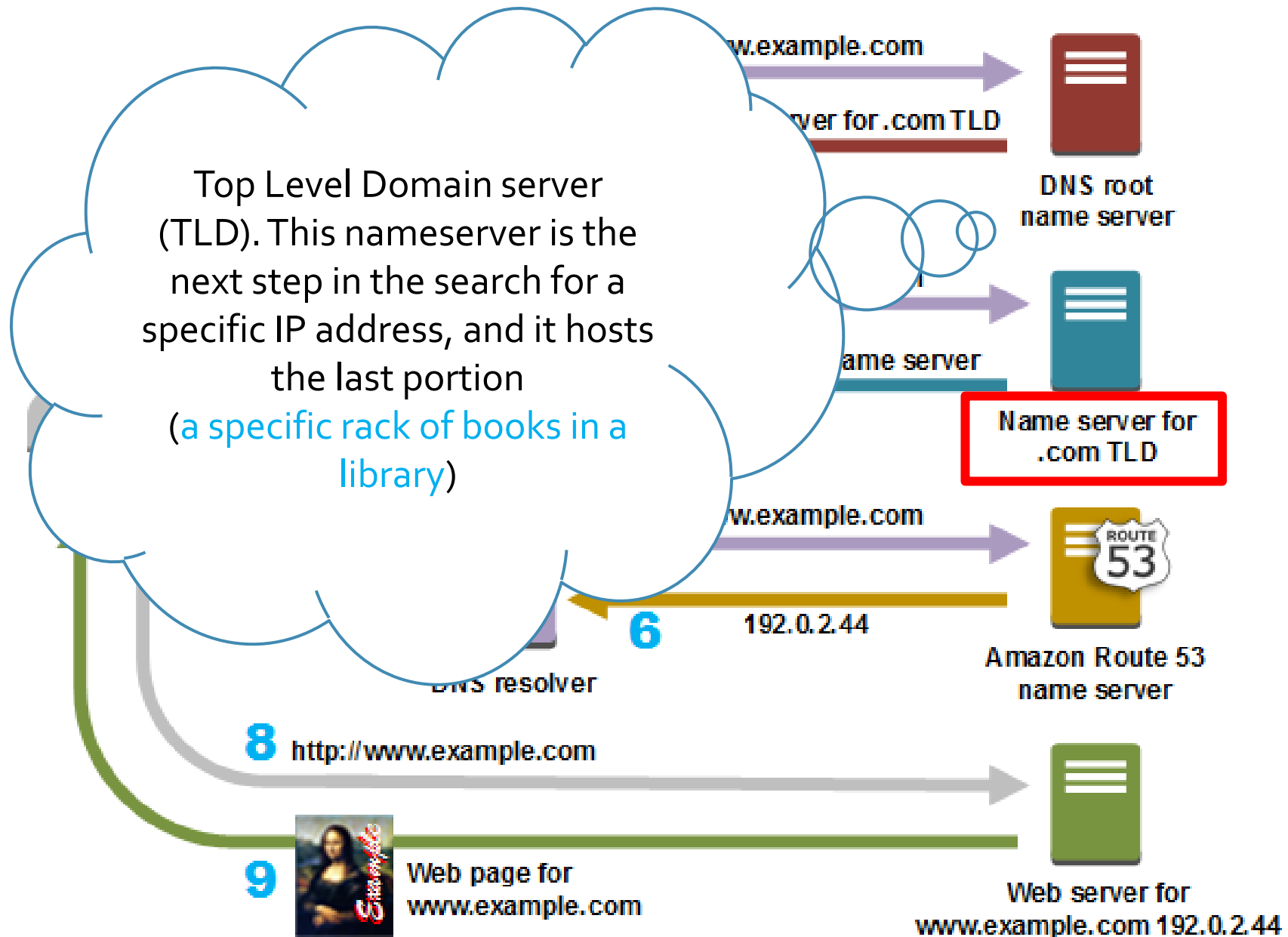
URL Structure

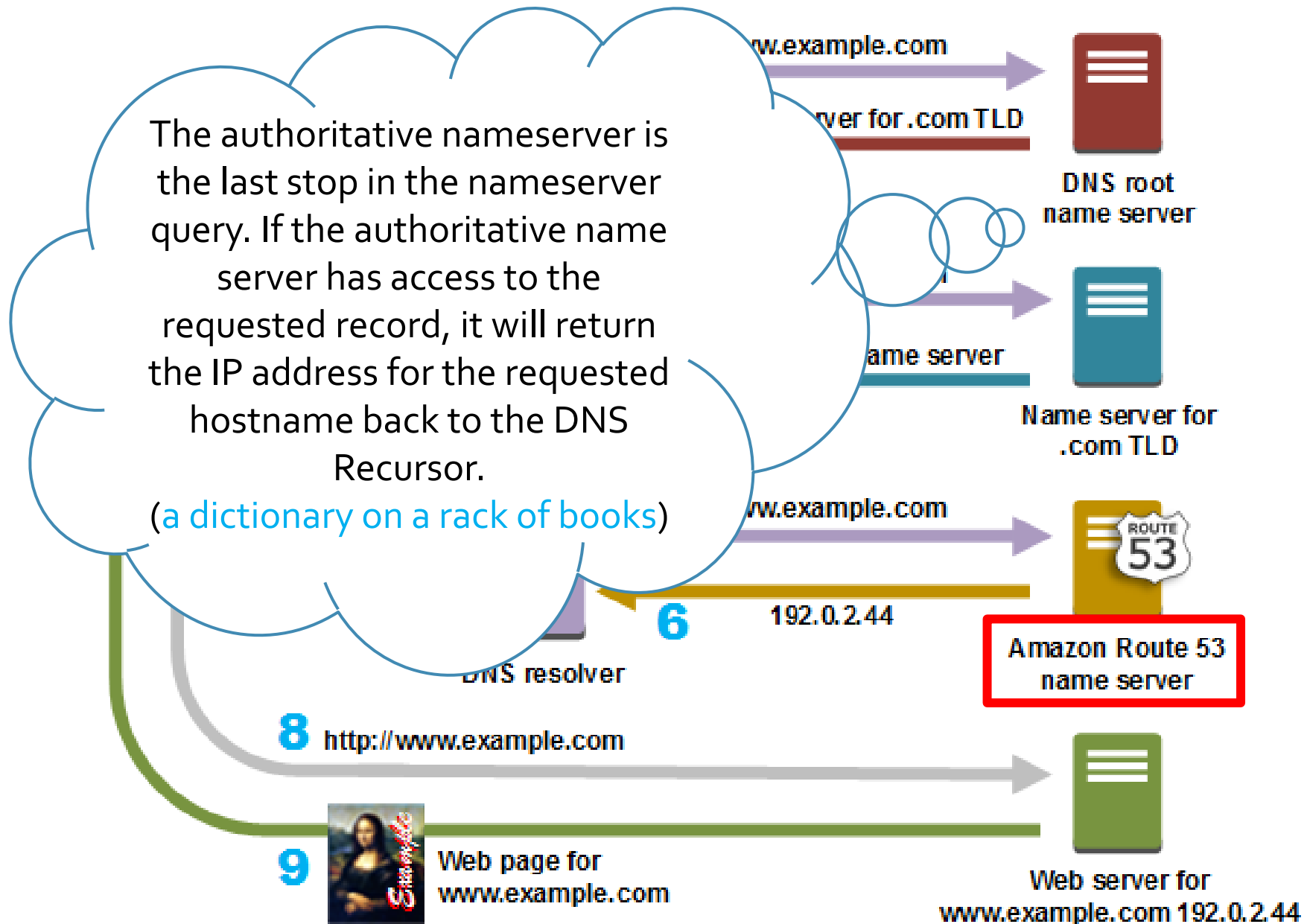




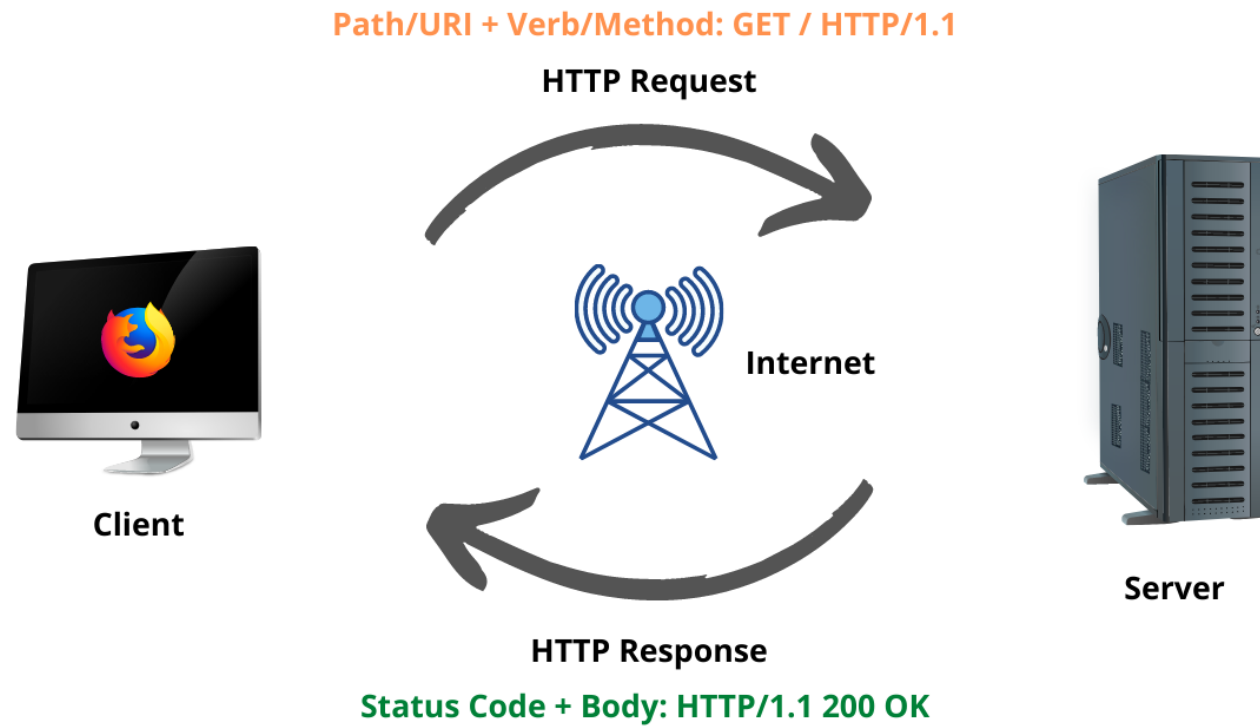








HTTP Request / Response



*Thank
you!*